RAPPORT DE TRAVAUX PRATIQUES : ANALYSE DE VULNÉRABILITÉS AVEC OPENVAS

1. Présentation des outils

Le cadre de ce TP repose sur l'utilisation de scanners de vulnérabilités, outils essentiels pour identifier les failles de sécurité dans un système d'information.

- **Nessus :** Scanner propriétaire de référence, connu pour sa facilité d'utilisation et sa précision.
- **OpenVAS (GVM) :** La principale alternative open-source à Nessus. Plus complexe à configurer, il offre cependant une flexibilité totale et une base de signatures de vulnérabilités très complète.

2. Installation et Mise en œuvre (Manipulation)

L'installation a été réalisée sur **Kali Linux** en utilisant la technologie de conteneurisation **Docker** pour simplifier le déploiement.

Étapes réalisées :

1. **Vérification du service Docker :** Le service a été démarré et activé avec les commandes `systemctl start docker` et `enable docker`. Un `status` a confirmé que le moteur était opérationnel.
2. **Déploiement de l'image :** Exécution du conteneur avec la commande :

   ```
   sudo docker run -d -p 9392:9392 immauss/openvas
   ```

3. **Accès à l'interface :**

   L'interface web GSA (Greenbone Security Assistant) a été accédée via l'URL : `https://localhost:9392`.

   Note technique : Lors du téléchargement des couches de l'image (Pulling), nous avons assuré l'intégrité de l'image via son hash SHA256

```
┌──(kali㉿kali)-[~]
└─$ sudo systemctl status docker
● docker.service - Docker Application Container Engine
     Loaded: loaded (/usr/lib/systemd/system/docker.service; enabled; preset: enabled)
     Active: active (running) since Fri 2026-04-17 09:52:18 EDT; 1 day 22h ago
 Invocation: c0ad8486f7a64419bddc023d8dcb84a3
TriggeredBy: ● docker.socket
       Docs: https://docs.docker.com
   Main PID: 542929 (dockerd)
      Tasks: 25
     Memory: 55.8M (peak: 388.2M swap: 14.5M swap peak: 16.4M)
        CPU: 41min 36.525s
     CGroup: /system.slice/docker.service
             ├─542929 /usr/sbin/dockerd -H fd:// --containerd=/run/containerd/containerd.sock
             ├─643383 /usr/sbin/docker-proxy -proto tcp -host-ip 0.0.0.0 -host-port 9392 -container-ip 172.17.0.2 -container-port 9392 -use-listen-fd
             └─643390 /usr/sbin/docker-proxy -proto tcp -host-ip :: -host-port 9392 -container-ip 172.17.0.2 -container-port 9392 -use-listen-fd

Apr 18 09:54:09 kali dockerd[542929]: time="2026-04-18T09:54:09.834081592-04:00" level=info msg="Download failed, retrying (4/5): dial tcp: lookup auth.docker.io on >
Apr 18 09:54:29 kali dockerd[542929]: time="2026-04-18T09:54:29.841297502-04:00" level=info msg="Download failed, retrying (4/5): dial tcp: lookup auth.docker.io on >
Apr 18 09:54:44 kali dockerd[542929]: time="2026-04-18T09:54:44.841681418-04:00" level=error msg="Download failed after 5 attempts: net/http: request canceled while >
Apr 18 09:55:09 kali dockerd[542929]: time="2026-04-18T09:55:09.862924561-04:00" level=error msg="Download failed after 5 attempts: dial tcp: lookup auth.docker.io o>
Apr 18 09:55:09 kali dockerd[542929]: time="2026-04-18T09:55:09.875992250-04:00" level=info msg="Attempting next endpoint for pull after error: dial tcp: lookup auth>
Apr 19 06:12:16 kali dockerd[542929]: time="2026-04-19T06:12:16.278389225-04:00" level=info msg="Download failed, retrying (1/5): unexpected EOF"
Apr 19 06:19:37 kali dockerd[542929]: time="2026-04-19T06:19:37.275125764-04:00" level=info msg="Download failed, retrying (2/5): unexpected EOF"
Apr 19 08:00:00 kali dockerd[542929]: time="2026-04-19T08:00:00.894162242-04:00" level=warning msg="Failed to allocate and map port" eid=49f92c02a6e7822748338fcd89f5>
Apr 19 08:00:05 kali dockerd[542929]: time="2026-04-19T08:00:05.140177050-04:00" level=info msg="ignoring event" container=74e713fb28aaa4b3aef4b25bebfc1ee6dc3da307be>
Apr 19 08:00:14 kali dockerd[542929]: time="2026-04-19T08:00:14.018501514-04:00" level=error msg="Handler for POST /v1.51/containers/74e713fb28aaa4b3aef4b25bebfc1ee6>
...skipping...
● docker.service - Docker Application Container Engine
```

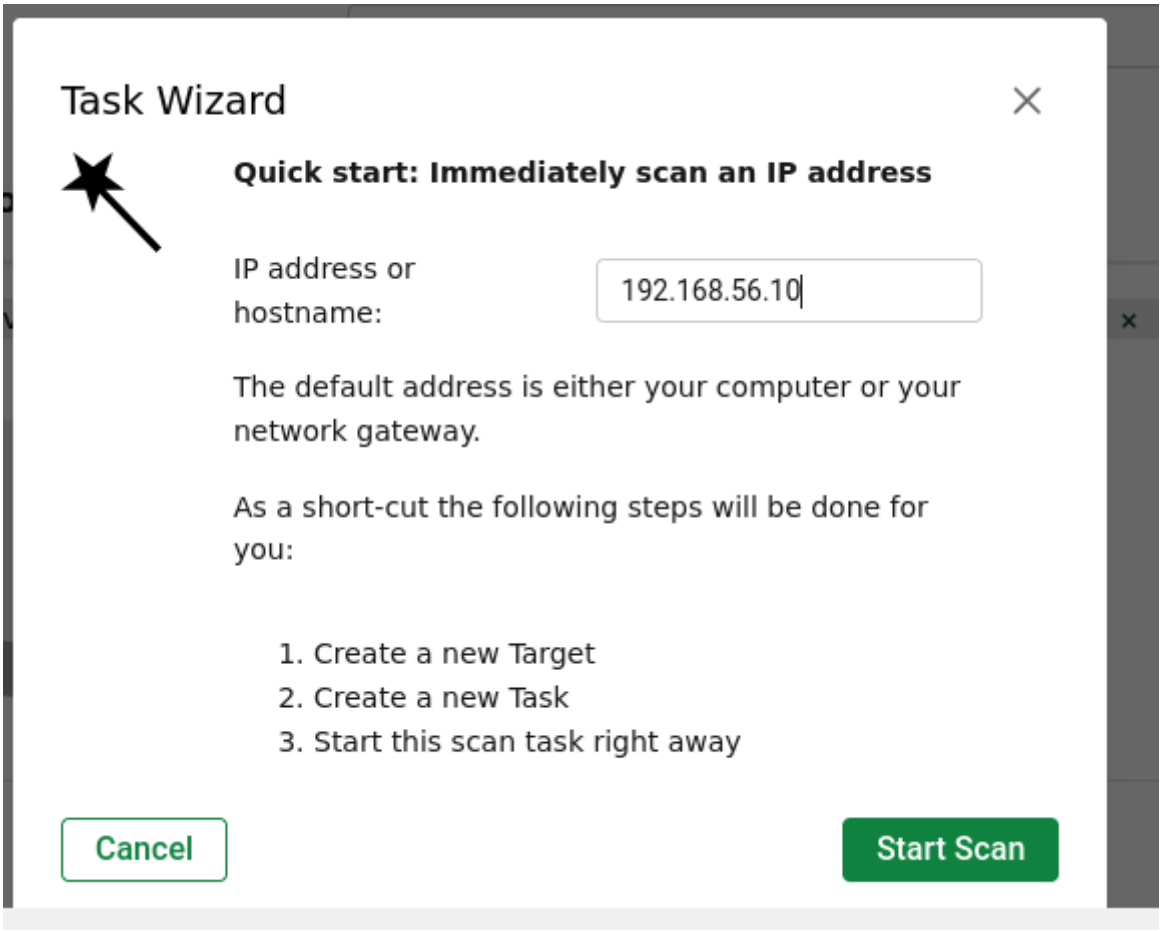
```
└─$ sudo docker run -d -p 9392:9392 immauss/openvas
[sudo] password for kali:
Unable to find image 'immauss/openvas:latest' locally
latest: Pulling from immauss/openvas
6a7e0620566c: Pull complete
aa9d88a882f7: Pull complete
d87b1cb1922a: Pull complete
ab06ad33276c: Pull complete
d7d559d04a17: Pull complete
e2b0d66f291d: Pull complete
1450cfb9c575: Pull complete
ab85775083d2: Pull complete
28bd8a2a75f7: Pull complete
8c44e194e19b: Pull complete
aca74bdff25f: Pull complete
cc495de32044: Pull complete
7ef1fe4a3b34: Pull complete
982770dd7501: Pull complete
52e58d875de5: Pull complete
1f61208972a1: Pull complete
dff1da059c01: Pull complete
175dbd626696: Pull complete
c90007d7cf1b: Pull complete
61792b610b35: Pull complete
9cc2278b0f71: Pull complete
ce20f5083ebb: Pull complete
b9e4a630c52a: Pull complete
7664605793a2: Pull complete
4f4fb700ef54: Pull complete
a4e44cf912c9: Pull complete
30c852f0edc0: Pull complete
23bc60e54bdf: Pull complete
Digest: sha256:b9fc9928d066846cbc8e0a22f882c64a9acf32a8f95c7fbf7d0bff3aff22d792
Status: Downloaded newer image for immauss/openvas:latest
```

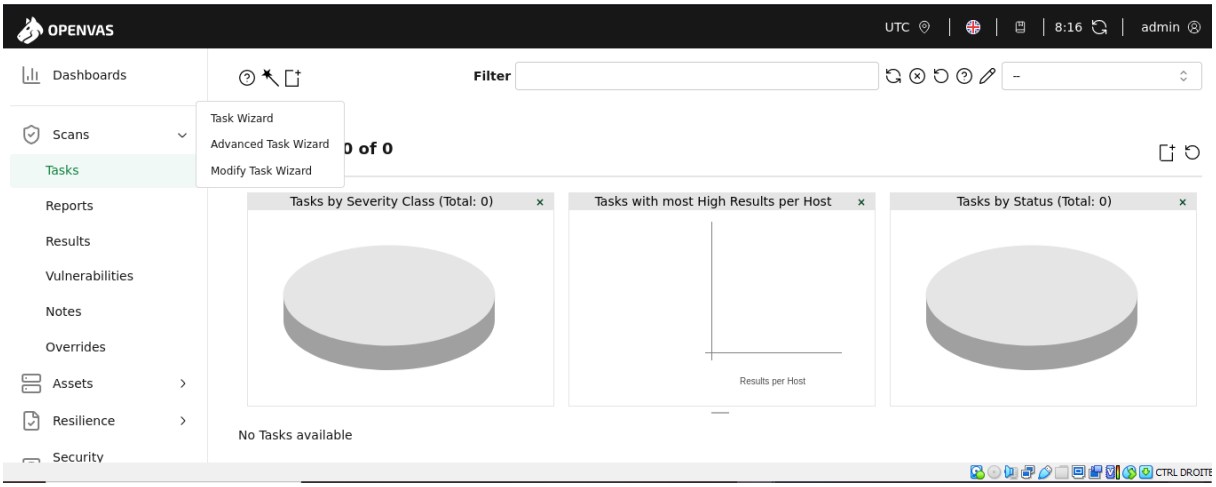
```
┌──(kali㉿kali)-[~]
└─$ sudo systemctl start docker

┌──(kali㉿kali)-[~]
└─$ sudo systemctl enable docker
Synchronizing state of docker.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable docker
```

3. Configuration et Lancement du Scan

Une fois l'interface OpenVAS accessible, la procédure de scan a été initiée.

- **Cible (Target) :** Une adresse IP spécifique a été configurée (`192.168.56.10`).
- **Méthode :** Utilisation du **Task Wizard** pour une configuration rapide. Cet assistant automatise la création de la cible, de la tâche et le lancement immédiat du scan.





4. Analyse des vulnérabilités (Résultats)

Le scan permet d'identifier des failles classées par niveau de sévérité (High, Medium, Low).

- **CVE (Common Vulnerabilities and Exposures) :** Chaque faille est identifiée par un numéro unique permettant de consulter la documentation mondiale.
- **Impact :** Analyse du risque (ex: exécution de code à distance, déni de service).
- **Remédiation :** OpenVAS propose des solutions de correction (mise à jour de patchs, modification de configuration).

---

5. Comparaison : Nessus vs OpenVAS

Critère	Nessus	OpenVAS
Facilité	Très facile (Interface intuitive)	Complexe (Configuration Docker/Logs)
Entreprise	Standard (Payant pour usage pro)	Alternative sérieuse (Gratuit/Open-source)
Gratuité	Limitée (Version Essentielle)	Oui (Totalement gratuit)

---

6. Analyse professionnelle et Conclusion

Quel outil est le plus adapté en entreprise ?

Le choix dépend du contexte :

1. **Nessus** est privilégié par les consultants pour sa rapidité de déploiement et la clarté de ses rapports destinés aux clients.
2. **OpenVAS** est idéal pour les administrateurs systèmes et les équipes SecOps qui souhaitent intégrer un scan continu sans coût de licence élevé, tout en gardant la main sur la configuration profonde de l'outil.

   Conclusion : Ce TP a permis de maîtriser le cycle complet de gestion des vulnérabilités, de l'installation technique sur Kali Linux à l'interprétation des résultats de scan. La maîtrise de Docker est ici un atout majeur pour la portabilité de l'outil de sécurité.

Questions de réflexion :

- **Pourquoi OpenVAS ?** Pour son aspect open-source et l'absence de restrictions sur le nombre d'IP scannées par rapport aux versions gratuites des outils propriétaires.

- **Limites rencontrées :** Nécessité d'une connexion internet stable pour le "pull" de l'image Docker et la mise à jour des signatures (feeds).